CIBERSEGURIDAD
ACTIVIDAD 5

Cartografiando el pentesting: análisis comparativo de metodologías de seguridad informática

EDUARDO GABRIEL MRQUECHO MEDINA
175805

PROSFESOR: SERVANDO LÓPEZ CONTRERAS

UNIVERSIDAD POLITECNICA DE SAN LUIS POTOSI

CRITERIO	MITRE ATT&CK	OWASP WSTG	NIST SP 800-115	OSSTMM	PTES	ISSAF
DESCRIPCIÓN	Base de conocimientos global sobre tácticas y técnicas de adversarios basada en observaciones del mundo real.	Guía técnica principal para pruebas de seguridad en aplicaciones web, enfocada en vulnerabilidades comunes.	Guía técnica para realizar pruebas y evaluaciones de seguridad en sistemas federales y privados	Estándar científico para la medición de la seguridad operativa mediante canales de comunicación	metodología y conjunto de directrices diseñadas para establecer un estándar en la realización de pruebas de penetración (pentesting), asegurando que sean sistemáticas, efectivas y cubran todos los aspectos de seguridad.	marco de trabajo (framework) de evaluación de seguridad de sistemas de información que describe técnicas, métodos y procedimientos para realizar pruebas de penetración (pentesting).
FASES DE IMPLEMENTACIÓN	12 Fases: 1. Reconocimiento 2. Desarrollo de Recursos 3. Acceso Inicial 4. Ejecución 5. Persistencia 6. Escalada de Privilegios 7. Evasión de Defensa 8. Acceso a Credenciales 9. Descubrimiento 10. Movimiento Lateral 11. Recolección y Mando y Control 12. Exfiltración e Impacto	12 fases: 1. Recopilación de información: Fingerprinting del servidor y mapeo de la aplicación. 2. Pruebas de gestión de configuración e implementación: Revisión de seguridad en infraestructura y configuración. 3. Pruebas de gestión de identidad: Mapeo de roles y pruebas de registro de usuarios. 4. Pruebas de autenticación: Detección de credenciales por defecto y fallos en el inicio de sesión. 5. Pruebas de autorización: Pruebas de elevación de privilegios y escalada de caminos. 6. Pruebas de gestión de sesiones: Análisis de cookies y manejo de sesiones. 7. Pruebas de validación de entrada: Detección de inyecciones (SQLi), XSS y manipulación de datos. 8. Pruebas de manejo de errores: Análisis de fugas de información. 9. Pruebas de criptografía: Verificación de la seguridad en la capa de transporte. 10. Pruebas de lógica empresarial: Verificación de la integridad de los flujos de negocio. 11. Pruebas del lado del cliente: Pruebas de XSS basado en DOM. 12. Pruebas de API: Validación de servicios web.	1. Planificación : • Definición de objetivos, alcance (IPs, redes), reglas de compromiso (RoE) y puntos de contacto. • Obtención de autorizaciones legales y organizativas necesarias antes de iniciar pruebas. 2. Descubrimiento : • Recopilación de información técnica (reconocimiento) sobre la infraestructura. • Escaneo de red, puertos y vulnerabilidades para identificar posibles puntos de entrada. • Validación manual de los hallazgos para evitar falsos positivos. 3. Ataque : • Intento de explotar las vulnerabilidades identificadas para ganar acceso o elevar privilegios. • Ejecución controlada de pruebas (ej. contraseñas, ingeniería social). • Mantenimiento del acceso y análisis del impacto sin dañar el sistema. 4. Informe: • Documentación exhaustiva de los hallazgos, vulnerabilidades explotadas y riesgos. • Entrega de un informe para audiencias técnicas y ejecutivas. • Recomendaciones de mitigación y remediación para mejorar la seguridad.	1. Planificación y Definición del Alcance (Lanzamiento del Proyecto): Define objetivos, limitaciones, reglas de compromiso y los sistemas a evaluar. 2. Recopilación de Información (Fase Inductiva): Busca obtener información pública o confidencial para descubrir fallos de gestión de datos, incluyendo inteligencia competitiva y revisión de privacidad. 3. Análisis de Seguridad (Fase Interactiva): Examina los cinco componentes clave: información, procesos, tecnologías de internet, comunicaciones y seguridad física. 4. Pruebas Activas/Intervención (Investigación): Se ejecutan pruebas de penetración, simulaciones de ataques y verificación de vulnerabilidades en tiempo real. 5. Análisis de Resultados y Reporte: Analiza la información recopilada, calcula métricas de seguridad y genera el informe final con recomendaciones.	7 Fases 1. Interacciones previas (Pre-engagement): Definición del alcance, objetivos y reglas de compromiso. 2. Recopilación de inteligencia (Intelligence Gathering): Investigación sobre el objetivo (fuentes abiertas, escaneo, etc.). 3. Modelado de amenazas (Threat Modeling): Identificación de los activos más valiosos y posibles atacantes. 4. Análisis de vulnerabilidades (Vulnerability Analysis): Búsqueda de debilidades en los sistemas. 5. Explotación (Exploitation): Simulación de un ataque real para aprovechar las vulnerabilidades. 6. Post-explotación (Post Exploitation): Evaluación del valor del sistema comprometido y mantenimiento del acceso. 7. Informes (Reporting): Documentación detallada de los hallazgos y recomendaciones.	1. Planificación y Preparación (Planning and Preparation) • Definición de objetivos • Reglas de participación • Reunión de preparación 2. Evaluación (Assessment) • Recopilación de información • Mapeo de red • Identificación de vulnerabilidades • Penetración (Explotación) • Elevación de privilegios • Enumeración adicional • Compromiso de usuarios/sitios remotos • Mantenimiento del acceso • Limpieza de huellas 3. Reporte, Limpieza y Destrucción de Artefactos • Informe • Limpieza • Destrucción de evidencia
OBJETIVO PRINCIPAL	Crear una base de conocimientos completa, estructurada y de acceso global sobre tácticas, técnicas y procedimientos (TTPs) utilizados por adversarios durante ciberataques reales	Proporcionar un marco de trabajo integral, estandarizado y basado en el consenso para evaluar la seguridad de aplicaciones y servicios web, ayudando a desarrolladores y profesionales de seguridad a identificar vulnerabilidades y mejorar la seguridad del software.	Proporcionar directrices técnicas estructuradas para planificar, realizar y documentar pruebas y evaluaciones de seguridad, tales como análisis de vulnerabilidades y pruebas de penetración	Proporcionar un marco estructurado, científico y abierto para realizar auditorías de seguridad operativas	Roporcionar una metodología estandarizada, completa y estructurada para realizar pruebas de penetración (pentesting) de alta calidad.	Proporcionar una metodología exhaustiva, estructurada y estandarizada para evaluar la seguridad de los sistemas de información, permitiendo identificar vulnerabilidades, probarlas y mitigarlas.
ESCENARIOS DE USO	Emulación de adversarios, búsqueda proactiva de amenazas (threat hunting), análisis de brechas defensivas, desarrollo de inteligencia de amenazas y evaluación de la madurez del SOC.	Pruebas de Penetración (Pentesting) de Caja Negra Pruebas de Caja Blanca y Revisión de Código Integración en el Ciclo de Vida de Desarrollo Seguro (S-SDLC) Auditorías de Cumplimiento y Normatividad Entrenamiento y Capacitación Técnica	Diseño de Metodologías de Pentesting (Caja Blanca/Gris/Negra) Escaneos de Vulnerabilidades de Red Auditoría de Configuraciones y Cumplimiento Pruebas de Seguridad en Redes Inalámbricas (Wi-Fi)	Auditorías de Seguridad Operativa (Penetration Testing) Auditoría de Seguridad Física Verificación de Seguridad en Telecomunicacione Análisis de "Social Engineering" (Seguridad Humana) Cumplimiento y Reportes Ejecutivos	Contrataciones comerciales de Pentesting de red e infraestructura.	Análisis forense inicial y auditorías técnicas de configuración de servidores.
ORIENTACIÓN	Defensiva/Ofensiva: Mapea cómo atacan para saber cómo defender.	Ofensiva: Pruebas de penetración específicas al software	Evaluación: Gestión de riesgos y procesos de auditoría.	Evaluación/Científica: Auditoría operativa y medición de confianza.	Ofensiva: Metodología paso a paso para el atacante profesional.	Ofensiva/Técnica: Manual técnico detallado de herramientas.
AUTORES / ORGANISMOS	MITRE Corporation (Financiado por el gobierno de EE.UU.).	OWASP Foundation (Comunidad global sin fines de lucro).	National Institute of Standards and Technology (NIST)	ISECOM (Institute for Security and Open Methodologies).	Grupo de expertos independientes (Liderado por Dave Kennedy y otros).	OISSG (Information Systems Security Group).
URL OFICIAL	attack.mitre.org	owasp.org/www-project-wstg	csrc.nist.gov	isecom.org	http://www.pentest-standard.org/index.php/Main_Page	oissg.org
CERTIFICACIONES	1. Certificaciones Oficiales: MAD20 (MITRE ATT&CK Defender) 2. Certificaciones de Terceros (Basadas en MITRE) 3. Micro-certificaciones y Badges	1. eWPT y eWPTX (eLearnSecurity / INE) 2. GWAPT (GIAC Web Application Penetration Tester) 3. OSWA y OSWE (OffSec)	1. CISA (Certified Information Systems Auditor) - ISACA 2. CySA+ (CompTIA Cybersecurity Analyst) 3. CEH (Certified Ethical Hacker) - EC-Council 4. GSEC (GIAC Security Essentials) - SANS Institute	1. OPST (OSSTMM Professional Security Tester) 2. OPSA (OSSTMM Professional Security Analyst) 3. OPSE (OSSTMM Professional Security Expert)	Sin certificacion propia. Certificaciones asociadas: • OSCP (Offensive Security Certified Professional) • CompTIA PenTest+ • eJPT (eLearnSecurity Junior Penetration Tester) • eCPPT (eLearnSecurity Certified Professional Penetration Tester) • CEH (Certified Ethical Hacker) de EC-Council • CPTS (Certified Penetration Testing Specialist) • GXPN (GIAC Exploit Researcher and Advanced Penetration Tester)	Sin certificacion propia. Certificaciones asociadas: • Google Cybersecurity Professional Certificate • Certificaciones de (ISC) • Certificaciones de EC-Council • Certificaciones de ISACA
VERSIONES VIGENTES	**v14.x / v15 (2026). Actualizaciones semestrales**	v4.2 (Estable) / v5.0 (Draft 2026).		v3.0 (Manual actual) / v4.0 (En desarrollo).	v1.1 Estándar continuo	v2.1 (Referencia histórica archivada)

Conclusion

Este análisis me permite concluir que la ciberseguridad no se trata de elegir una sola metodología, sino de saber combinar las fortalezas de cada una según el reto que enfrentemos. Mientras que NIST y OSSTMM nos dan el orden y la métrica científica para trabajar con profesionalismo, OWASP y MITRE nos aterrizan a la realidad técnica de los ataques actuales en la web y el comportamiento real de los adversarios. Dominar estos marcos de trabajo y sus certificaciones no solo me prepara para ejecutar auditorías técnicas impecables, sino que me da la capacidad de proteger infraestructuras de manera estratégica, transformando datos complejos en soluciones reales para las organizaciones

Bibliografia

ISECOM. (2021). OSSTMM 3: The Open Source Security Testing Methodology Manual. Institute for Security and Open Methodologies.

National Institute of Standards and Technology (NIST). (2008). Technical Guide to Information Security Testing and Assessment (Special Publication 800-115). U.S. Department of Commerce.

OWASP Foundation. (2024). Web Security Testing Guide (WSTG) Version 5.0.

MITRE Corporation. (2024). ATT&CK®: Adversary Tactics, Techniques, and Common Knowledge.